

~~##~~ Intrusion Detection Systems (IDS)

Prevention vs Detection -

Firewalls & cryptography are prevention mechanisms.

However, security assumes a perfectly airtight system is impossible to build.

Therefore we use IDS for detection -

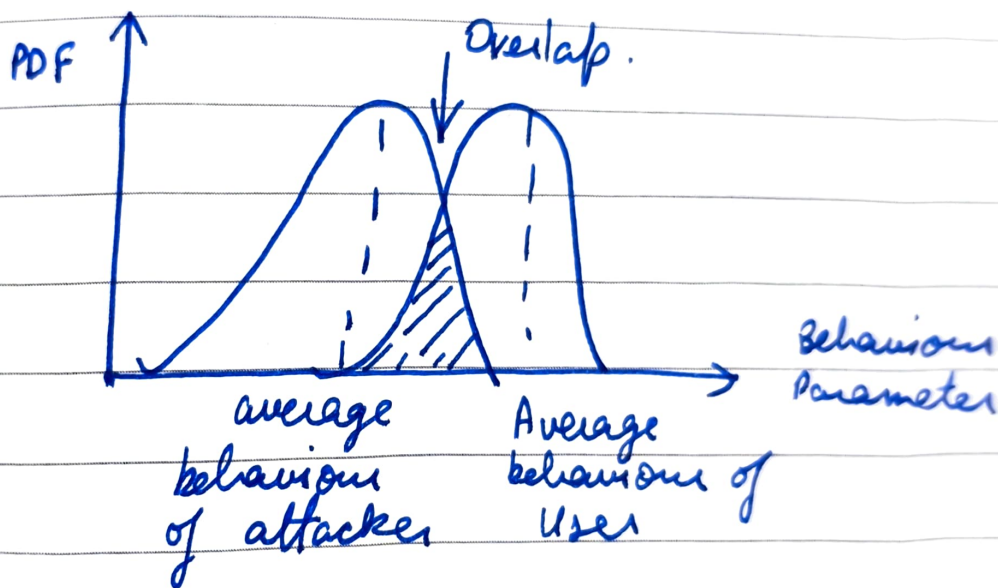
Every IDS is built on one core assumption, An attacker's behaviour is measurably different from a legitimate user's behaviour.

Ideally, a legitimate user would do "safe" things & attackers only do "bad" things.

Date ___/___/___

In reality their behaviours overlap.

A legitimate user might forget their password & try 5 times in a row, which looks exactly like an attacker's brute force attack



If we set our detection threshold anywhere near that overlap, the system makes mistakes.

FP (False Positive): IDS flags user as attacker

FN (False Negative): IDS Fails to flag an attack

Bayes' calculations

$$P_1[\text{attack}] = 0.1\% \\ = 0.001$$

$$P_1[\text{alarm}|\text{attack}] = 99\%$$

(an amazing IDS that is 99% accurate in detecting an attack)

$$P_1[\text{attack}|\text{alarm}] = ?$$

what are the chances of an actual attack if an alarm was raised

$$P_1[\text{attack}|\text{alarm}] = P_1[\text{alarm}|\text{attack}] \times \frac{P_1[\text{attack}]}{P_1[\text{alarm}]}$$

Even if this probability comes out
0.1 i.e. 10%

Date ___/___/___

90% of times it's a false alarm.
↳ False positive rate (FPR)

even with 0.1% FPR,
if a server processes 10 mil requests, this means you still have to manually process 10,000 false alarms a day.

Example to build up to
NIDS & HIDS.

Directory traversal

GET /amazon.exe?profile=../../../../etc/passwd

1. Network Intrusion Detection System.

NIDS sits on the network wire
(near the main router) & passively

watches all the packets flying by.

- It can scan the HTTP (unencrypted) packet for suspicious strings like ".../..." or "etc /passwd"
- It is cheap & easy to deploy.
You just attach it to the router & it can monitor hundreds of servers at once without touching them.
- Hackers can easily avoid it using encoding or transforming the payload (%2e %2e %2f instead of ".../..."). If the payload is encrypted by TLS (HTTPS) NIDS fails.

2. Host-based Intrusion Detection System (HIDS)

A HIDS is installed directly inside the server or database.

- Instead of watching packets, it watches the Host's behaviour.
Ex. It can monitor the OS's system calls.

- It is expensive & difficult to manage. • You have to install & maintain custom software on every single server.

————— X ————— X —————

But, How does an IDS decide if an ~~attack~~ event is an attack.

Two fundamental detection modes

- Signature Based
- Anomaly Detection

1. Signature Detection.

This model works like traditional antivirus.

The security team writes explicit rules (signature) that define known "bad patterns".

- IDS scans traffic or logs looking for exact matches of these rules.
- If a signature matches, you are almost certainly under attack.

Disadvantage: completely useless against new, never-before-seen (zero-day) attacks.

If the hacker tweaks their malware just enough to change its byte-sequence, the signature won't match & IDS will let it pass.

2. Anomaly (Profile-Based) detection

To catch ~~of~~ the zero-day attacks that signature detection misses, we use statistics.

It doesn't look for "known evil" it tries to describe "normal".

The IDS monitors the network for weeks to build a statistical baseline (mean & std. deviation) for every user & machine.

Tracks metrics like login frequency, session length, & the amount of data copied.

- It can catch brand new attacks & insider threats.
- Still prone to False Positives.